CNSD

Centro Nacional
de Seguridad Digital

Gestión de Riesgos de Seguridad de la Información

PERÚ Presidencia del Consejo de Ministros

Ponle PUNCHE y ganamos todos PERÚ

Índice

1. Introducción 4

1.1. Definición de Gestión de Riesgos de Seguridad de la Información 4

1.2. La Importancia de una buena Gestión de Riesgos 5

1.3. Objetivo de la guía 5

2. Gestión de Riesgos de seguridad de la Información 6

2.1. Proceso de Gestión de Riesgo de seguridad de la Información 6

2.2. Ciclos de Gestión de Riesgos de seguridad de la Información 7

3. Establecimiento del Contexto 8

3.1. Establecimiento y Mantenimiento de los criterios de Riesgo de seguridad de la Información 8

3.1.1. Criterios de Aceptación del Riesgo 9

3.1.2. Criterios para realizar Evaluaciones de Riesgos de Seguridad de la Información 9

4. Proceso de Evaluación de los Riesgos de Seguridad de la Información 10

4.1. Identificación de los Riesgos 11

4.2. Análisis de los Riesgos 11

4.2.1. Análisis de las consecuencias potenciales 12

4.2.2. Análisis de la probabilidad 12

4.2.3. Determinación de los niveles de riesgo 12

4.3. Evaluación de los Riesgos 12

5. Proceso de Tratamiento de los Riesgos de Seguridad de la Información 12

5.1. Plan de Tratamiento del Riesgo 13

6. Comunicación y Consulta 13

7. Monitoreo y Revisión 14

7.1. Propósitos del Monitoreo y Revisión: 14

7.2. Actividades del Monitoreo y Revisión: 14

7.3. Beneficios del Monitoreo y Revisión: 15

8. Conclusiones 15

8.1. Resumen de Puntos Clave 15

8.2. Importancia de la Mejora Continua en la Gestión de Riesgos: 16

9. Anexos 16

9.1. Ejemplos de Evaluación de Riesgos de Seguridad de la Información 17

9.2. Plantillas y Herramientas 17

9.2.1. Plantillas para Identificar los Riesgos: 17

9.2.2. Plantillas para Analizar los Riesgos 18

9.2.3. Plantillas para Evaluar los Riesgos 18

9.2.4. Plantillas para Tratar los Riesgos 19
10. Referencias 20

Índice de Tablas

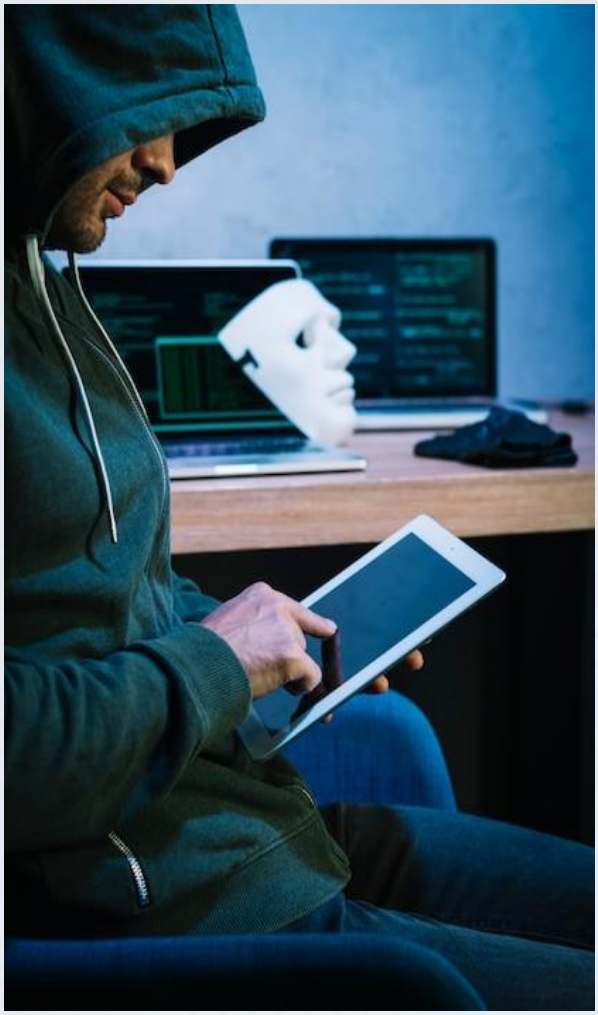
Tabla 1: Evaluación de Riesgos de Seguridad de la Información 17
Tabla 2: Inventario de Activos 17
Tabla 3: Inventario de Amenazas 17
Tabla 4: Inventario de Vulnerabilidades 17
Tabla 5: Escala de Consecuencias 18
Tabla 6: Escala de Probabilidad 18
Tabla 7: Nivel de Riesgo 18
Tabla 8: Nivel de Tolerancia 18
Tabla 9: Evaluación de Riesgos 19
Tabla 10: Opciones de Tratamiento 19
Tabla 11: Plan de Tratamiento 19

1. Introducción

1.1. Definición de Gestión de Riesgos de Seguridad de la Información

La **gestión de riesgos de seguridad de la información** es el proceso mediante el cual una organización **identifica, evalúa y prioriza** los riesgos que pueden afectar sus activos de información. Este proceso es esencial para asegurar la **confidencialidad, integridad y disponibilidad** de la información, permitiendo a la organización cumplir con sus objetivos estratégicos y operativos.

Una buena Gestión de Riesgos de Seguridad de la Información nos previene de:



- **Amenazas Externas**: Incluyen actores malintencionados como hackers, grupos de cibercriminales y estados-nación que buscan explotar las vulnerabilidades de la organización.
- **Amenazas Internas**: Empleados malintencionados o negligentes que pueden comprometer la seguridad de la información a través de acciones intencionadas o accidentales.
- **Errores Humanos**: Configuraciones incorrectas, envío de datos sensibles a destinatarios erróneos y fallos en el seguimiento de los protocolos de seguridad establecidos.
- **Vulnerabilidades Tecnológicas**: Fallos en el software, hardware o infraestructura que pueden ser explotados por atacantes para comprometer los sistemas.
- **Eventos Naturales**: Desastres naturales como terremotos, inundaciones y huracanes que pueden dañar la infraestructura de información y causar interrupciones operativas

La gestión de riesgos no se trata de eliminar completamente todos los riesgos, ya que esto es prácticamente imposible. En su lugar, se enfoca en **entender y definir una tolerancia al riesgo** adecuada para la organización, desarrollando estrategias efectivas para abordar estos riesgos y mantener un equilibrio adecuado entre la seguridad y las oportunidades de negocio.

1.2. La Importancia de una buena Gestión de Riesgos

La gestión de riesgos de seguridad de la información es esencial para minimizar el impacto de amenazas y vulnerabilidades que puedan comprometer la seguridad de la información. Una gestión de riesgos eficaz permite a las organizaciones identificar, evaluar y mitigar los riesgos antes de que se materialicen, asegurando así la continuidad de las operaciones y la protección de los activos de información.

Las amenazas y vulnerabilidades en el entorno de la información están en constante evolución, y la capacidad de una organización para anticiparse y responder a estos riesgos es crucial. La identificación temprana de amenazas potenciales y la evaluación precisa de sus posibles consecuencias son fundamentales para el desarrollo de estrategias de mitigación efectivas.

Razones Clave para Implementar una Gestión de Riesgos

- **Protección de Activos de Información**: La gestión de riesgos asegura que los activos críticos de información estén protegidos contra amenazas internas y externas. Esto incluye proteger la confidencialidad, integridad y disponibilidad de los datos.
- **Cumplimiento Normativo**: Muchas industrias y sectores están sujetos a regulaciones estrictas sobre la gestión de información. Una gestión de riesgos efectiva ayuda a garantizar el cumplimiento de estas normativas y evita sanciones legales y financieras.
- **Reducción de Vulnerabilidades**: Al identificar y evaluar las vulnerabilidades, las organizaciones pueden implementar controles para reducir el riesgo de explotación. Esto incluye la implementación de parches de seguridad, la mejora de la configuración de sistemas y la capacitación del personal.
- **Mejora de la Resiliencia Organizacional**: La capacidad de una organización para resistir y recuperarse de eventos adversos se fortalece mediante la gestión de riesgos. Las organizaciones pueden desarrollar planes de contingencia y recuperación que les permitan continuar operando incluso en situaciones críticas.
- **Toma de Decisiones Informadas**: La gestión de riesgos proporciona a la alta dirección una comprensión clara de los riesgos a los que se enfrenta la organización. Esto permite tomar decisiones informadas sobre la asignación de recursos y la priorización de medidas de seguridad.



1.3. Objetivo de la guía

El objetivo de esta guía es proporcionar un enfoque estructurado y exhaustivo para la gestión de riesgos de seguridad de la información, cubriendo cada uno de los pasos clave desde la identificación hasta la mitigación y monitoreo continuo. El enfoque aquí adoptado se basa en las mejores prácticas del sector, alineado con la NTP ISO/IEC 27005:2022, que ofrece una visión metodológica y sistemática de la gestión de riesgos de seguridad de la información.

Esta guía no se limita únicamente a la identificación y evaluación de riesgos, sino que también abarca aspectos relacionados con la comunicación interna y externa, el cumplimiento de normativas regulatorias y la adopción de lecciones aprendidas para fortalecer la infraestructura de seguridad a futuro.

Además de cubrir los aspectos técnicos, la guía incluye ejemplos prácticos y recomendaciones específicas para que las organizaciones puedan implementar mejoras inmediatas en su infraestructura y gestión de riesgos. Esto es especialmente relevante para todos los sectores que manejan datos críticos, donde la confidencialidad y la integridad de los datos son primordiales.

Identificación de Riesgos

Este componente implica reconocer los riesgos potenciales que podrían comprometer los activos de información. Los riesgos pueden surgir de diversas fuentes, incluyendo actores externos, errores humanos, fallos en los procesos internos y vulnerabilidades en sistemas.

Evaluación de Riesgos

Este paso consiste en analizar la probabilidad de ocurrencia y el impacto de los riesgos identificados. Se utilizan métodos cualitativos y cuantitativos para determinar la severidad de cada riesgo.

Tratamiento de Riesgos

Una vez evaluados, los riesgos deben ser tratados mediante la implementación de medidas para mitigar, transferir, aceptar o evitar los riesgos. Las estrategias pueden incluir la aplicación de controles de seguridad, seguros, ajustes en los procesos operativos y capacitaciones.

Monitoreo y Revisión de Riesgos

Este componente implica supervisar continuamente los riesgos y la efectividad de las medidas de control implementadas. Se deben realizar revisiones periódicas y actualizar las estrategias de gestión de riesgos según sea necesario.

En resumen, esta guía tiene como misión equipar a las organizaciones con las herramientas, conocimientos y mejores prácticas necesarias para mitigar el impacto de los riesgos, fortalecer su ciber resiliencia y garantizar la continuidad de las operaciones.

2. Gestión de Riesgos de seguridad de la Información

2.1. Proceso de Gestión de Riesgo de seguridad de la Información

El proceso de gestión de riesgos de seguridad de la información puede repetirse para evaluar y tratar los riesgos. Con cada iteración, se puede profundizar más en la evaluación, equilibrando el tiempo y esfuerzo dedicados a la identificación de controles y garantizando una evaluación adecuada de los riesgos. Es importante establecer el contexto adecuado, tanto interno como externo, para esta gestión.

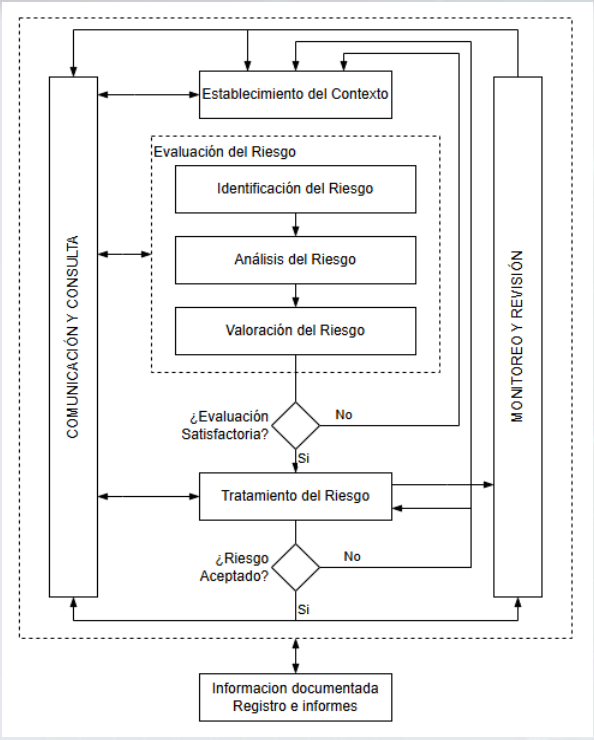
Si una evaluación de riesgos da suficiente información para decidir cómo reducir los riesgos a un nivel aceptable, se puede pasar a la siguiente fase. Si no, hay que repetir la evaluación, ajustando el contexto o consultando expertos para obtener la información necesaria.

El tratamiento de riesgos es un proceso continuo que implica:

- Formular y seleccionar opciones de tratamiento
- Planificar y aplicar el tratamiento
- Evaluar su eficacia
- Decidir si los riesgos residuales son aceptables
- Aplicar nuevos tratamientos si es necesario

En caso de que el tratamiento no logre reducir los riesgos a niveles aceptables, se puede intentar un nuevo tratamiento o repetir la evaluación.

El conocimiento de las amenazas o vulnerabilidades pertinentes mejora la toma de decisiones en cada iteración de la evaluación de riesgos.



2.2. Ciclos de Gestión de Riesgos de seguridad de la Información

La evaluación y el tratamiento de riesgos deben actualizarse periódicamente y adaptarse a los cambios. Esto se puede dividir en dos ciclos de gestión de riesgos:

- **Ciclo estratégico:** Aquí se consideran los activos de la empresa, las fuentes de riesgo, las amenazas y los objetivos en función de los cambios en el contexto general de la organización. Este ciclo sirve para una actualización general de la evaluación de riesgos y también para identificar nuevos riesgos.
- **Ciclo operativo:** Aquí, los elementos del ciclo estratégico sirven como información de entrada. Este ciclo implica la revisión y actualización de los escenarios y el tratamiento de riesgos correspondiente.

El ciclo estratégico se realiza a largo plazo o cuando hay cambios importantes, mientras que el ciclo operativo es más corto y se ajusta a los riesgos detallados identificados y evaluados. En ambos ciclos, puede haber muchas evaluaciones de riesgos con diferentes contextos y alcances.



3. Establecimiento del Contexto

Una organización se define como una persona o grupo de personas que tiene sus propias funciones con responsabilidades, autoridades y relaciones para lograr sus objetivos.

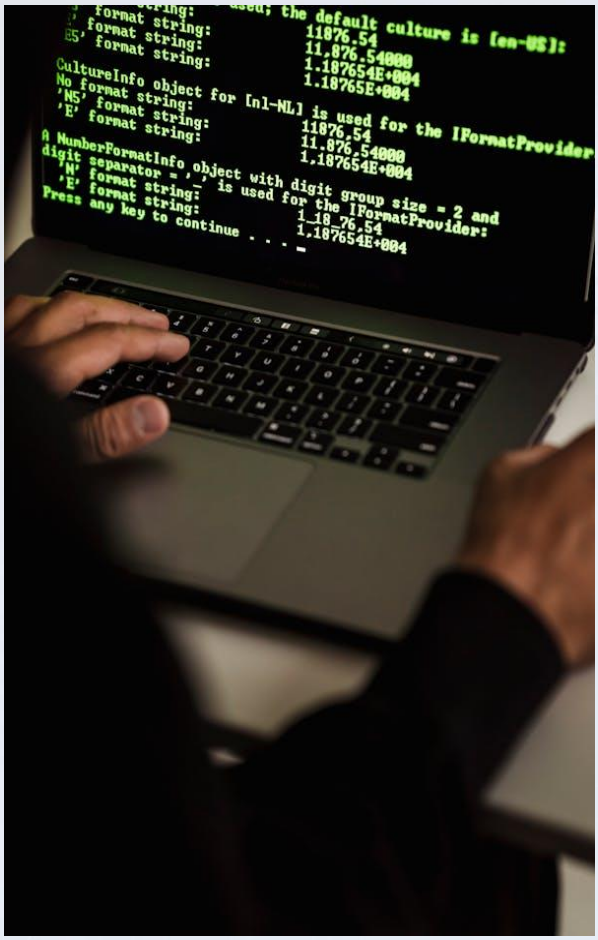
Entorno Interno y Externo: Evaluar factores internos y externos que pueden influir en la capacidad de la organización para alcanzar sus objetivos. Ejemplos incluyen la cultura organizacional, el apetito de riesgo, las tendencias del mercado y el entorno regulatorio.

Partes Interesadas: Identificar las partes interesadas y sus necesidades y expectativas. Esto puede incluir clientes, empleados, reguladores y socios comerciales. Esto incluye la identificación de todos los documentos de referencia que definen las normas y controles de seguridad y que se aplican en el ámbito de la evaluación de riesgos de seguridad de la información.

Alcance de la Gestión de Riesgos: Definir el alcance del proceso de gestión de riesgos, incluyendo los activos, los procesos y las áreas de la organización que serán evaluados.

3.1. Establecimiento y Mantenimiento de los criterios de Riesgo de seguridad de la Información

Las organizaciones definen sus criterios de riesgo de seguridad de la información según las siguientes consideraciones:



- **Naturaleza y tipo de incertidumbres:** Identificar las incertidumbres que pueden afectar los resultados y objetivos, tanto tangibles como intangibles.
- **Definición, predicción y medición de consecuencias y probabilidad:** Determinar cómo se van a definir, predecir y medir las consecuencias y la probabilidad de los riesgos.
- **Factores relacionados con el tiempo:** Considerar cómo el tiempo puede influir en los riesgos y su impacto.
- **Coherencia en el uso de mediciones:** Asegurar la consistencia en la aplicación de las mediciones de riesgo.
- **Determinación del nivel de riesgo:** Establecer cómo se determinará el nivel de riesgo para diferentes escenarios.
- **Combinaciones y secuencias de múltiples riesgos:** Considerar cómo interactúan y se combinan múltiples riesgos.
- **Capacidad de la organización:** Evaluar la capacidad de la organización para gestionar los riesgos identificados.

3.1.1. Criterios de Aceptación del Riesgo

Se debe establecer los niveles de riesgo que la organización está dispuesta a aceptar, teniendo en cuenta:

- **Coherencia:** Asegurarse de que los criterios de aceptación del riesgo de seguridad de la información estén alineados con los criterios generales de la organización.
- **Delegación de Autoridad:** Identificar los niveles de gestión con autoridad delegada para tomar decisiones sobre la aceptación de riesgos.
- **Múltiples Umbrales:** Los criterios de aceptación de riesgos pueden tener varios umbrales, y la autoridad para aceptarlos puede asignarse a diferentes niveles de gestión.
- **Bases de los Criterios:** Los criterios pueden basarse en la probabilidad y las consecuencias, o incluir un análisis coste/beneficio entre las pérdidas esperadas y el coste de los controles.
- **Diferentes Clases de Riesgo:** Aplicar distintos criterios de aceptación de riesgos según la clase de riesgo, como el cumplimiento normativo, que generalmente no se retiene, frente a riesgos contractuales que pueden ser aceptables.

3.1.2. Criterios para realizar Evaluaciones de Riesgos de Seguridad de la Información

Se debe establecer la importancia de los riesgos en términos de sus consecuencias, probabilidad y nivel de riesgo, se debe de considerar la idoneidad de las actividades de Gestión de Riesgos, las cuales incluyen:

- Cantidad y concentración de la información.
- Valor estratégico de los procesos empresariales relacionados
- Criticidad de la información y sus activos
- Importancia operativa de la disponibilidad, confidencialidad e integridad
- Expectativas y percepciones de las partes interesadas
- Consecuencias negativas como la pérdida de buena voluntad y reputación
- Coherencia con los criterios de riesgo de la organización
- Nivel de clasificación de la información

Finalmente, los criterios de evaluación de riesgos deben ser estandarizados en toda la organización para facilitar la comunicación, comparación y agregación de riesgos en diferentes ámbitos de la organización.

3.1.2.1. Criterios de Consecuencias

Se determina la magnitud del daño resultante de la perdida de confidencialidad, integridad y disponibilidad de la información. Los aspectos más importantes a considerar son:

- Pérdida de vidas o daños a individuos/grupos
- Pérdida de valor empresarial y financiero
- Pérdida de libertad, dignidad o derecho a la intimidad
- Deterioro de operaciones internas o de terceros
- Daños a la reputación del público
- Incumplimientos de requisitos legales, reglamentarios o contractuales
- Impacto negativo en las partes interesadas y el medio ambiente



3.1.2.2. Criterios de Probabilidad

Se puede expresar en términos probabilísticos o frecuentistas, adaptándose según el contexto. Escalas demasiado amplias pueden generar errores, y las fuentes de riesgo más relevantes se priorizan según su probabilidad y relación con el Sistema de Gestión de Seguridad de la Información (SGSI).

La determinación de los criterios de probabilidad considera factores como:

- Eventos accidentales
- Exposición a amenazas
- Vulnerabilidades
- Fallos tecnológicos
- Actos humanos.



3.1.2.3. Criterios para determinar el Nivel de Riesgo

El propósito de las escalas para el nivel de riesgo es ayudar a decidir entre retener o tratar riesgos y priorizarlos. El nivel de riesgo evaluado determina la urgencia del tratamiento. Dependiendo de la situación, se debe considerar el nivel de riesgo inherente (sin controles) o el nivel de riesgo actual (con controles efectivos implementados). La organización debe clasificar los riesgos basados en:

- Criterios de consecuencia y probabilidad.
- Consecuencias a nivel estratégico, táctico y operativo.
- Requisitos legales, reglamentarios y contractuales.
- Riesgos más allá del ámbito de la organización, incluidos los efectos imprevistos sobre terceros.

4. Proceso de Evaluación de los Riesgos de Seguridad de la Información

La organización debe evaluar los riesgos de seguridad de la información o definir uno específico si no existe. La evaluación de riesgos ayuda a priorizarlos para su tratamiento, basándose en sus consecuencias, probabilidad y otros criterios establecidos.

Es importante utilizar instrumentos detallados para obtener resultados coherentes, válidos y reproducibles, y asegurarse de que los riesgos de seguridad de la información se alineen con el enfoque general de gestión de riesgos de la organización para facilitar comparaciones y evitar consideraciones aisladas.

4.1. Identificación de los Riesgos

La identificación de riesgos implica encontrar, reconocer y describir riesgos, así como identificar sus fuentes y eventos. El objetivo es generar una lista de riesgos que puedan afectar los objetivos de seguridad de la información. Existen dos enfoques principales para esta tarea:

- **Enfoque basado en eventos:** Identifica escenarios estratégicos evaluando eventos y consecuencias a través de las preocupaciones de la alta dirección y requisitos organizacionales. Este enfoque se enfoca en riesgos críticos y utiliza datos históricos cuando están disponibles.
- **Enfoque basado en activos:** Evalúa riesgos inspeccionando activos, amenazas y vulnerabilidades. Los activos que requieren protección se identifican y categorizan, destacando sus dependencias e interacciones con fuentes de riesgo.

La identificación de riesgos es crucial, pues cualquier riesgo no identificado no será considerado en el análisis posterior. Deben considerarse los riesgos sin importar si su fuente está bajo control de la organización, y realizar evaluaciones iterativas para captar todos los niveles de detalle.

La organización también debe de identificar a los propietarios de riesgos o definir criterios para ello. Estos propietarios deben tener la autoridad y responsabilidad necesarias para gestionar los riesgos y comprender los problemas para tomar decisiones informadas sobre su tratamiento. El nivel de riesgo y el activo afectado sirven como base para identificar a los propietarios del riesgo.

Para lograr una buena identificación de riesgos, algunas de las acciones a realizar son:

- **Identificar y catalogar los Activos:** Crear un inventario detallado de todos los activos de información, incluyendo datos, hardware, software y personal. Utilizar herramientas como listas de verificación y entrevistas con personal clave.
- **Identificación de Amenazas:** Identificar amenazas que pueden afectar a los activos, tales como ataques cibernéticos, desastres naturales, errores humanos y fallos tecnológicos. Utilizar metodologías como el análisis de escenarios y las simulaciones.
- **Identificación de Vulnerabilidades:** Evaluar las vulnerabilidades que pueden ser explotadas por las amenazas. Realizar evaluaciones técnicas de seguridad, como pruebas de penetración y análisis de vulnerabilidades.

4.2. Análisis de los Riesgos

El análisis de riesgos tiene como objetivo determinar el nivel de riesgo basado en las consecuencias y la probabilidad de cada riesgo identificado. Puede realizarse de manera cualitativa (usando términos como alto, medio, bajo), cuantitativa (con valores numéricos como coste monetario o frecuencia) o semicuantitativa (escalas cualitativas con valores asignados). El análisis debe enfocarse en los riesgos y controles que, al gestionarse adecuadamente, aumentan la probabilidad de alcanzar los objetivos de la organización. Aunque el análisis puede ser complejo, es suficiente utilizar estimaciones iniciales para una toma de decisiones efectiva.

Una vez analizados, los riesgos deben ser clasificados para determinar su prioridad. Esto puede incluir:

- Matrices de Riesgo: Herramientas que permiten clasificar los riesgos en función de su probabilidad e impacto.
- Mapas de Riesgo: Representaciones visuales de los riesgos que muestran su severidad y prioridad.

4.2.1. Análisis de las consecuencias potenciales

Consiste en evaluar el impacto que pueden tener los riesgos identificados en los objetivos de la organización. Este análisis ayuda a determinar la gravedad de los efectos de dichos riesgos, permitiendo priorizar su tratamiento.

4.2.2. Análisis de la probabilidad

Se centra en evaluar la posibilidad de que un riesgo identificado ocurra dentro de un período de tiempo determinado. Este análisis permite determinar qué tan probable es que se materialicen los riesgos, basándose en información histórica, datos disponibles y el conocimiento experto.

4.2.3. Determinación de los niveles de riesgo

Se evalúa y categoriza los riesgos identificados en función de su probabilidad de ocurrencia y la gravedad de sus consecuencias. Permite priorizar los riesgos y definir las acciones necesarias para su gestión. Utilizando una matriz de niveles de riesgo, se pueden visualizar y comparar los riesgos, facilitando la toma de decisiones sobre su tratamiento.

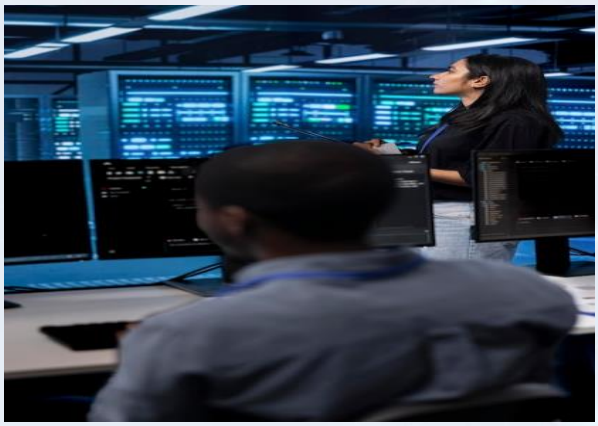
4.3. Evaluación de los Riesgos

Una vez identificados los riesgos y asignados los valores de probabilidad y gravedad, las organizaciones deben aplicar sus criterios de aceptación de riesgos para determinar si son aceptables o necesitan tratamiento prioritario. La evaluación de riesgos implica comparar los riesgos evaluados con los criterios definidos previamente, considerando el grado de confianza en la evaluación.

Los niveles de riesgo deben validarse mediante consenso entre propietarios de riesgos y especialistas. Es crucial que los propietarios comprendan bien los riesgos de los que son responsables y que esta comprensión coincida con la valoración objetiva. Cualquier disparidad entre los niveles de riesgo valorados y percibidos debe investigarse para determinar cuál es más realista.

5. Proceso de Tratamiento de los Riesgos de Seguridad de la Información

El objetivo fundamental del tratamiento de los riesgos y oportunidades es el de definir de manera específica la forma en la que se deben implementar las opciones elegidas para reducir el riesgo, de forma que los involucrados puedan entender lo dispuesto y que además permita también realizar un seguimiento y control del avance de dichas acciones en relación con las planificadas.



5.1. Plan de Tratamiento del Riesgo

Establece las estrategias y acciones específicas que la organización debe llevar a cabo para gestionar los riesgos identificados. Este plan busca reducir la probabilidad de ocurrencia y/o consecuencias de los riesgos a niveles aceptables, alineándose con los objetivos y la tolerancia al riesgo de la organización. El plan debe ser detallado, asignando responsabilidades claras, recursos necesarios y un cronograma para la implementación de las medidas de tratamiento. Además, debe incluir criterios para evaluar la efectividad de las acciones y permitir ajustes continuos según sea necesario.

6. Comunicación y Consulta

La comunicación y consulta son elementos esenciales en la gestión de riesgos de seguridad de la información. Este proceso asegura que todas las partes interesadas, tanto internas como externas, estén informadas y participen activamente en la identificación, evaluación y tratamiento de los riesgos. La comunicación efectiva facilita la comprensión de los riesgos y las medidas adoptadas para mitigarlos, mejorando la toma de decisiones y fomentando una cultura de seguridad en toda la organización. Además, la consulta permite recoger las percepciones y experiencias de diferentes grupos, enriqueciendo el análisis y asegurando que las estrategias de gestión de riesgos sean adecuadas y completas. Es vital mantener un flujo constante de información y retroalimentación para ajustar y mejorar continuamente el enfoque de gestión de riesgos.

- **Transparencia:** mantener a las partes interesadas informadas sobre el proceso de gestión de riesgos.
- **Recolección de Retroalimentación:** recoger comentarios y sugerencias de las partes interesadas para mejorar el proceso.
- **Involucramiento Activo:** promover la participación activa de las partes interesadas en el proceso de gestión de riesgos.
- **Mejora Continua:** utilizar la retroalimentación para realizar mejoras continuas en la gestión de riesgos.



7. Monitoreo y Revisión

El monitoreo y revisión son procesos continuos y esenciales dentro de la gestión de riesgos de seguridad de la información. Estos procesos aseguran que las estrategias y medidas implementadas para gestionar los riesgos sean efectivas y se mantengan actualizadas frente a nuevos desafíos y cambios en el entorno organizacional.

7.1. Propósitos del Monitoreo y Revisión:

- **Asegurar la Eficacia:** Verificar que los controles de seguridad implementados están funcionando según lo previsto y que los riesgos se están gestionando adecuadamente.
- **Identificar Cambios:** Detectar cambios en el entorno interno y externo que puedan influir en los riesgos existentes o generar nuevos riesgos.
- **Evaluar el Rendimiento:** Medir el rendimiento de las estrategias de gestión de riesgos a través de indicadores clave y métricas específicas.
- **Mejora Continua:** Proporcionar retroalimentación para mejorar y ajustar las políticas, procedimientos y controles de seguridad de la información.

7.2. Actividades del Monitoreo y Revisión:

1. **Revisión Periódica:** Realizar revisiones regulares y programadas de los riesgos identificados, los controles implementados y las estrategias de tratamiento.
2. **Evaluaciones de Auditoría:** Llevar a cabo auditorías internas y externas para verificar la conformidad con las políticas de seguridad y los estándares aplicables.
3. **Análisis de Incidentes:** Investigar y analizar los incidentes de seguridad ocurridos para identificar debilidades en los controles y áreas de mejora.
4. **Actualización de Registros:** Mantener registros actualizados de los riesgos, controles y las acciones tomadas, asegurando que la documentación sea precisa y completa.
5. **Comunicación Continua:** Asegurar una comunicación efectiva entre todas las partes interesadas sobre los resultados del monitoreo y revisión, y sobre cualquier cambio necesario en las estrategias de gestión de riesgos.



7.3. Beneficios del Monitoreo y Revisión:

- **Resiliencia Organizacional:** Aumentar la capacidad de la organización para adaptarse y responder eficazmente a los riesgos emergentes.
- **Cumplimiento Normativo:** Garantizar que la organización cumpla con las normativas y estándares de seguridad de la información.
- **Confianza de las Partes Interesadas:** Fortalecer la confianza de clientes, socios y otras partes interesadas en la capacidad de la organización para proteger su información.

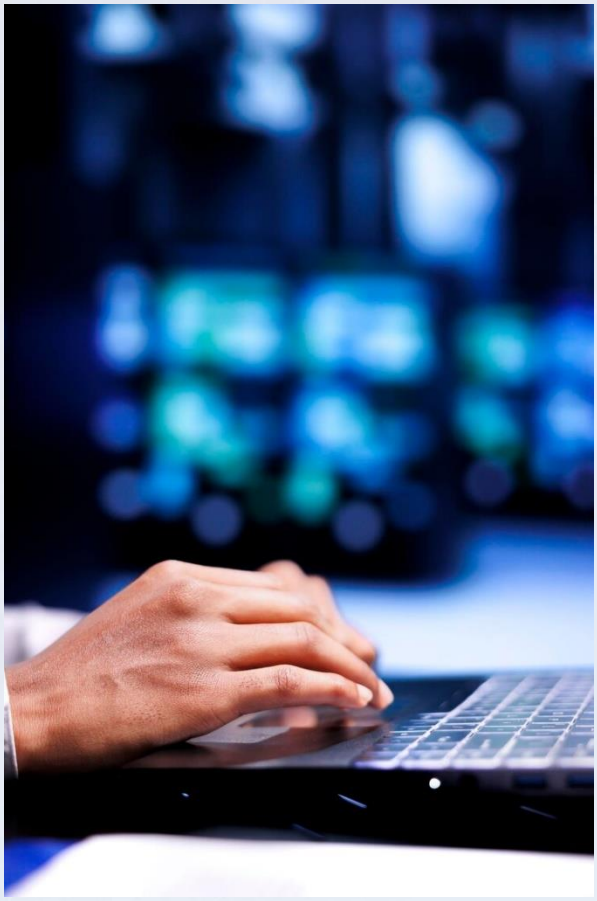
8. Conclusiones

La gestión de riesgos de seguridad de la información es un componente crítico para asegurar la protección de los activos informáticos y la continuidad operativa de la organización. A lo largo de esta guía, hemos abordado los elementos esenciales del proceso de gestión de riesgos, desde la identificación y análisis de riesgos hasta la implementación de planes de tratamiento y monitoreo constante.

8.1. Resumen de Puntos Clave

1. **Identificación de Riesgos:**

Es fundamental reconocer y describir los riesgos que puedan afectar los objetivos de seguridad de la información.



2. **Análisis y Valoración:**

Evaluar tanto la probabilidad como las consecuencias de los riesgos para determinar su nivel y priorizar su tratamiento.

3. **Planes de Tratamiento:**

Definir estrategias claras y acciones específicas para mitigar los riesgos identificados, asignando responsabilidades y recursos adecuados.

4. **Comunicación y Consulta:**

Mantener una comunicación efectiva y una consulta continua con todas las partes interesadas, asegurando que comprendan y participen en el proceso de gestión de riesgos.

5. **Monitoreo y Revisión:**

Realizar revisiones periódicas y monitoreo constante para asegurar la efectividad de las medidas implementadas y adaptarlas a cambios en el entorno.

8.2. Importancia de la Mejora Continua en la Gestión de Riesgos:

La mejora continua en la gestión de riesgos de seguridad de la información es esencial para mantener la organización protegida y resiliente frente a los desafíos y amenazas constantes del entorno.

- **Adaptabilidad:** La mejora continua permite a la organización adaptarse rápidamente a cambios en el entorno, nuevas amenazas y vulnerabilidades emergentes.
- **Eficiencia:** Al perfeccionar y optimizar constantemente los procesos de gestión de riesgos, se puede mejorar la eficiencia y efectividad de las medidas de seguridad.
- **Innovación:** Fomenta una cultura de innovación en la gestión de riesgos, buscando nuevas estrategias y tecnologías para mejorar la protección de la información.
- **Resiliencia Organizacional:** Incrementa la capacidad de la organización para resistir y recuperarse de incidentes de seguridad, asegurando la continuidad del negocio.
- **Cumplimiento Normativo:** Mantiene a la organización alineada con las normativas y estándares de seguridad de la información, adaptándose a nuevos requisitos y regulaciones.
- **Confianza de las Partes Interesadas:** Refuerza la confianza y credibilidad de la organización ante clientes, socios y otras partes interesadas, al demostrar un compromiso constante con la seguridad y la mejora continua.



9. Anexos

Los anexos proporcionan información adicional y complementaria que apoya y amplía los contenidos presentados en esta guía de gestión de riesgos de seguridad de la información. En esta sección, se incluyen tablas y ejemplos prácticos que facilitan la comprensión y aplicación de los conceptos tratados a lo largo del documento.

Estas herramientas son esenciales para la implementación efectiva de las estrategias de gestión de riesgos y ofrecen una referencia útil y práctica para los profesionales de seguridad de la información.

9.1. Ejemplos de Evaluación de Riesgos de Seguridad de la Información

Tabla 1: Evaluación de Riesgos de Seguridad de la Información

Ejemplo 1: Ataque de Phishing	Ejemplo 2: Falla en el Servidor
• **Contexto:** Un empleado recibe un correo electrónico fraudulento. • **Activo Afectado:** Credenciales de acceso. • **Amenaza:** Phishing. • **Vulnerabilidad:** Falta de capacitación en seguridad. • **Impacto:** Compromiso de cuentas, pérdida de datos sensibles. • **Nivel Probabilidad:** Alta (muy probable). • **Nivel Consecuencia:** Alto (mayor). • **Tratamiento:** Implementar capacitación en seguridad y filtros de correo electrónico.	• **Contexto:** Un servidor crítico falla debido a un fallo de hardware. • **Activo Afectado:** Servidor de base de datos. • **Amenaza:** Falla de hardware. • **Vulnerabilidad:** Falta de redundancia. • **Impacto:** Interrupción del servicio, pérdida de datos. • **Nivel Probabilidad:** Media (probable). • **Nivel Consecuencia:** Alto (mayor). • **Tratamiento:** Implementar redundancia de hardware y planes de recuperación ante desastres.

9.2. Plantillas y Herramientas

9.2.1. Plantillas para Identificar los Riesgos:

Tabla 2: Inventario de Activos

ID del Activo	Nombre del Activo	Tipo de Activo	Propietario	Valoración
A001	Servidor de Base de Datos	Hardware	Departamento de TI	Alto
A002	Sistema de Gestión	Software	Departamento de TI	Alto
...				

Tabla 3: Inventario de Amenazas

ID de Amenaza	Categoría	Descripción	Fuente de la Amenaza
T001	Amenazas Físicas	Robo de equipos físicos	Externa: Criminales
T002	Amenazas Naturales	Terremoto que daña la Infraestructura	Externa: Naturales
T003	Fallos Técnicos	Fallos en la red que causan perdida de conectividad	Interna: Riesgo Técnico/Infraestructura
...			

Tabla 4: Inventario de Vulnerabilidades

ID de Vulnerabilidad	Categoría	Descripción	Fuente de la Vulnerabilidad
V001	Hardware	Fallos en Servidores	Interna: Equipos
V002	Personal	Falta de Capacitación en Seguridad	Interna: Empleados
...			

9.2.2. Plantillas para Analizar los Riesgos

Tabla 5: Escala de Consecuencias

Consecuencias	Valor	Descripción	Impacto
Catastrófico	**5**	Daños severos, pérdida de vidas, colapso de operaciones, pérdida irrecuperable de confianza y reputación.	Muy Alto
Mayor	**4**	Perdida financiera considerable, daño significativo a la reputación, interrupciones severas en las operaciones	Alto
Moderado	**3**	Impacto notorio en las operaciones, posible efecto en la reputación, pero recuperable.	Medio
Menor	**2**	Daños leves, con impacto limitado en las operaciones y sin afectar significativamente la reputación.	Bajo
Insignificante	**1**	Daños mínimos, no afectan las operaciones ni la reputación de la organización	Muy Bajo

Tabla 6: Escala de Probabilidad

Probabilidad	Valor	Descripción	Frecuencia Estimada
Muy Alta	**5**	Es casi seguro que ocurra.	>75%
Alta	**4**	Muy probable que ocurra.	50% - 75%
Moderada	**3**	Probable que ocurra.	25% - 50%
Baja	**2**	Poco probable que ocurra.	5% - 25%
Muy Baja	**1**	Es muy improbable que ocurra.	<5%

Tabla 7: Nivel de Riesgo

Nivel de Riesgo			Consecuencias				
			Catastrófico	Mayor	Moderado	Menor	Insignificante
			5	4	3	2	1
Probabilidad	Muy Alta	5	Muy Alto 25	Muy Alto 20	Alto 15	Alto 10	Medio 5
	Alta	4	Muy Alto 20	Alto 16	Alto 12	Medio 8	Bajo 4
	Moderada	3	Alto 15	Alto 12	Medio 9	Medio 6	Bajo 3
	Baja	2	Alto 10	Medio 8	Medio 6	Bajo 4	Muy Bajo 2
	Muy Baja	1	Medio 5	Bajo 4	Bajo 3	Muy Bajo 2	Muy Bajo 1

9.2.3. Plantillas para Evaluar los Riesgos

Tabla 8: Nivel de Tolerancia

Nivel de tolerancia	Nivel de Exposición	Tolerancia al Riesgo
IN: Inaceptable	**17 – 25**	Se debe implementar el cese de actividades y aprobar para una acción inmediata.
IM: Tolerable	**10 – 16**	Se debe revisar oportunamente para llevar a cabo estrategias de mejora.
MO: Adecuado	**5 – 9**	Se debe considerar un análisis posterior.
TO: Aceptable	**1 – 4**	No es necesario ninguna acción y se recomienda mantener las medidas de control.

Tabla 9: Evaluación de Riesgos

ID de Riesgo	Descripción	Impacto	Probabilidad	Nivel de Riesgo	Tolerancia al Riesgo	Medidas de Control	Responsable
R001	Acceso no autorizado	Alto	Moderada	Alto	Tolerable	Implementar autentificación multifactorial	Equipo de TI
R002	Ataque de malware	Muy Alto	Alta	Muy Alto	Inaceptable	Instalar software antimalware	Equipo de TI
R003	Fuga de información	Moderado	Moderada	Medio	Adecuado	Capacitar a los empleados	Recursos Humanos
...							

9.2.4. Plantillas para Tratar los Riesgos

Tabla 10: Opciones de Tratamiento

Opciones de Tratamiento	Definición
Evitar el Riesgo	Cambiar los procesos o actividades para eliminar el riesgo por completo.
Mitigar el Riesgo	Implementar controles para reducir la probabilidad o el impacto del riesgo.
Transferir el Riesgo	Transferir el riesgo a un tercero, como mediante un seguro.
Aceptar el Riesgo	Decidir que el riesgo es aceptable y no requiere acción adicional.

Tabla 11: Plan de Tratamiento

ID de Riesgo	Descripción	Acción de tratamiento	Responsable	Fecha de implementación	Estado
R001	Acceso no autorizado	Implementar autentificación multifactorial	Equipo de TI	15/02/2025	Completado
R002	Perdida de datos sensibles	Realizar backups diarios	Equipo de TI	15/01/2025	Completado
R003	Fuga de información	Capacitar a los empleados	Recursos Humanos	30/06/2025	En progreso
...					

10. Referencias

- ISO/IEC 27001:2022 - Tecnología de la Información. Técnicas de Seguridad. Sistemas de Gestión de Seguridad de la Información. Requisitos.
- ISO/IEC 27005:2022 - Tecnología de la Información. Ciberseguridad y Protección de la Privacidad. Gestión de Riesgos de Seguridad de la Información2.
- ISO 31000:2018 - Gestión del Riesgo. Directrices4.
- NIST SP 800-30 - Guide for Conducting Risk Assessments. National Institute of Standards and Technology (NIST).
- CMMI for Development, Version 1.3 - Carnegie Mellon University, Software Engineering Institute.
- Cobit 2019 - A Business Framework for the Governance and Management of Enterprise IT. ISACA.
- ITIL 4 - Information Technology Infrastructure Library. ITIL Foundation.
- The Risk IT Framework - ISACA. Un enfoque integrado a la gestión de riesgos relacionados con TI.
- Libros y artículos:
  - "Managing Risk: Methods for Software Systems Development" por Elaine M. Hall.
  - "Risk Management in Information Systems" por Darril Gibson.
  - "The Security Risk Assessment Handbook: A Complete Guide for Performing Security Risk Assessments" por Douglas Landoll.



PERÚ | Presidencia del Consejo de Ministros

Ponle PUNCHE y ganamos todos PERÚ

CNSD | Centro Nacional de Seguridad Digital

- alertas@cnsd.gob.pe
- incidentes@cnsd.gob.pe